Report

Upgrade Audit

by Asymptotic

Prepared by: Asymptotic
Subject: Independent review of the changes deployed on top of the audited baseline (on-chain package version 17).

Engagement

- **Auditor:** Mykhailo Burakhin, Lead Auditor
- **Dates:** 1–4 June 2026
- **Duration:** 3 person-days

What was reviewed

- **Repository:** `fireflyprotocol/bluefin-spot-contracts` (private), branch `main`
- **Package:** `bluefin_spot` — on-chain package **version 17**, owner `Immutable`, verified against the Sui mainnet fullnode.
- **Baseline:** `7957dacea871b5048d7cf6b365c059712f20edc2`, the final commit of Asymptotic's original audit.
- **Target:** `925896ef38be892975a82e8211352b6d2cf08b66`, the source of the deployed v17 package (11 commits on the baseline).
- **Scope:** every source and `Move.toml` change between the two, plus the Bluefin integer library the package now depends on. Unchanged logic was covered by the original audit; tests are out of scope.

Methodology

Manual review backed by machine-checked proofs, on code confirmed identical to the deployed bytecode.

- **Reviewed code is deployed code.** `sui client verify-source` (Sui CLI 1.62.0) rebuilt the target commit and matched the on-chain v17 bytecode for all 18 modules.

- **Manual review.** Every change, line by line, against the audited baseline: logic divergence, new permissionless entry points, capability gating, version checks, and on-chain object layout compatibility. The forked CLMM math was compared against upstream Cetus; the retained Cetus integer library is used only for its types.
- **Formal verification (Sui Prover 1.5.3).** Asymptotic's specifications were updated to the target and re-proven, including new specifications for the code this release introduces. The signed-integer conversion layer is proven to agree with reference signed-integer arithmetic, the CLMM math is proven for swap solvency and rounding direction, and tick-price conversion is proven correct, monotonic and invertible in Lean 4 over all 887,273 valid ticks. The Bluefin integer library is covered by Asymptotic's specifications. See the formal verification report.
- **Asymptotic Agent.** Drafted and reviewed the specifications, then ran 171 adversarial deep reviews trying to break them or find behavior they miss. It also assisted the manual review.

Nature of the upgrade

This release is a **dependency-migration release**, undertaken in response to the May-2025 Cetus exploit. The deployment removes the affected third-party arithmetic dependency entirely and re-routes all signed-integer math through a Bluefin-maintained library, behind a defensively written conversion layer that includes an explicit kill-switch against the upstream bug. On-chain object layouts are preserved, so the upgrade is binary-compatible. The core trading, accounting, and oracle logic is the established CLMM math, unchanged.

The accompanying changes are small and self-contained: a composable two-step pool-creation path, an admin-gated pool icon-URL setter (with a no-op guard and a new event), and event/visibility cleanups. The router's exact-out path now follows standard Uniswap-V3 partial-fill semantics; the caller's input-side slippage bound is retained.

Conclusion

We identified **no findings at any severity**. The migration is sound, on-chain object compatibility is preserved, and the supporting changes introduce no new permissionless attack surface.

This report reflects our review of the code changes at the commits and on-chain versions noted above. A review reduces the risk of certain classes of bugs but does not guarantee the absence of all vulnerabilities; only the reviewed changes and properties are covered. This report is provided for informational purposes only, not as financial, legal, or investment advice. No liability is assumed for losses arising from reliance on this report. Users should perform their own due diligence before interacting with any smart contract system.